MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 027 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · QUALITY AND COMPLIANCE

Your AS9100 QMS Already Runs Half of CMMC

Document control, CAPA, internal audit, and management review already run most of CMMC's governance half. The mapping, and the three gaps that remain.

BY **MAXINE** READING TIME · 6 MIN AS9100 · ISO-9001 · QMS · CMMC · EVIDENCE

quality manager at an AS9100 machine shop reads the CMMC clause in a new solicitation and hears a demand to build something from nothing: a governance program, staffed, audited, and proven, layered on top of a quarter that was already full. That reading is wrong, and it is wrong in the specific way that costs money. The shop does not need a governance program. It has one. It has run one for years, under a different name, for a different auditor, and the machinery inside it does most of the job CMMC is asking for.

Start with document control, because it is the discipline every AS9100 or ISO 9001 shop already treats as sacred. A controlled procedure carries a revision history, a named approval authority, and a rule against working from an uncontrolled copy - the whole point is that the document on the floor matches the document that was actually approved. That is precisely what NIST 800-171's control 3.12.4 asks of a system security plan: not that the SSP be accurate on the day it was written, but that it stay accurate as the system it describes changes underneath it. An SSP with no revision history and no named owner is a document nobody controls, and an assessor reads that the same way a quality auditor reads an uncontrolled work instruction on the shop floor - as evidence the system is unmanaged, not merely unfinished. A shop that will not let an operator run from last month's drawing already has the habit a current SSP requires. It has just never pointed that habit at the SSP.

A CAPA record and a POA&M entry ask for the same sequence: finding, root cause, action, verification, and closure signed by a named owner.

Corrective and preventive action is the same story wearing different vocabulary. A CAPA and a Plan of Action and Milestones entry ask for the identical lifecycle, and a POA&M item that jumps straight from finding to "fixed" with no root cause investigation is exactly the CAPA a quality auditor would reject on sight, for exactly the same reason: it treats the symptom and calls the disease cured. Nonconformance tracking runs the parallel case at the component level - a nonconforming part gets a disposition, a stated reason, and a record of who made that call - which is the same discipline a POA&M item needs when a control cannot close before the assessment and someone has to document why the residual risk is acceptable in the meantime.

Internal audit is the mechanism CMMC programs spend the most money trying to build from scratch, and it is the one already running on a published schedule inside every certified shop. An AS9100 internal audit walks a process against a standard on a calendar the quality manual commits to. Point that same auditor at the NIST 800-171A assessment objectives instead of the AS9100 clause structure, and the audit does not change its nature. It changes its checklist. The self-assessment a CMMC program needs before a C3PAO ever shows up is an internal audit with a different reference document, run by someone who already knows how to run one. Management review closes the loop the same way. It is the meeting a lot of technical security programs cannot actually produce on demand, and it is standing agenda in a certified QMS - leadership sign-off on risk, resourcing, and residual exposure, which is exactly what a POA&M closure needs from a named risk owner rather than from the engineer who did the work. A shop that already holds management review quarterly is not inventing a new meeting. It is putting one more topic on an agenda that already exists.

Training records close the governance loop in a shape MacZine has already tested for weakness. Issue Nº 017 found that most organizations run the training and still fail the control, because the record ties a headcount to a course name instead of a specific audience to specific completion. A QMS training record already carries the structure that control wants - job function tied to required training tied to a completion date - because a quality system has always had to prove a specific operator was qualified for a specific process before that operator touched a specific part. MacTech's own compliance document set applies the identical logic on the security side: each controlled document's required training audience is derived from the control table inside that document, not assigned from a fixed list of job titles, so the record it produces already answers who needed to know this and did they. That is the audience-to-completion structure Issue Nº 017 found missing almost everywhere else - already built, already audited, inside the QMS most of these readers run today.

Where the quality system stops

None of that makes the QMS sufficient on its own, and a piece that implied otherwise would leave the reader worse off than it found them. A QMS has no equivalent for defining a CUI boundary. Deciding which systems, which network segments, and which people actually touch controlled unclassified information is a scoping exercise a quality manual has never had to perform, because "which parts did we make" is not the same question as "where does regulated data live." It has no equivalent for implementing a technical control, either: multifactor authentication, validated encryption, and a hardened configuration baseline are engineering work, and no amount of document discipline substitutes for actually building them. And the test itself is not the same test. An AS9100 audit samples a slice of records and infers the rest of the system from it; an 800-171A assessment verifies each of 320 objectives directly, control by control, with no equivalent shortcut for the assessor to take. A shop that treats a CMMC assessment like a surveillance audit will be surprised by how little inference the assessor is willing to do on its behalf.

What the mapping is worth, stated in the terms that actually move a purchase order, is a correction to a number. The consulting quote most shops get assumes a governance program built from zero - policy authorship, a review cadence invented from scratch, an internal audit function hired and trained, a management review process stood up for the first time. None of that is true of a shop that already runs a certified QMS. The documentation set a Level 2 program implies still has to get built and mapped to the 110 requirements, and the technical controls still have to get engineered. But the governance half of that work - the machinery that keeps documents current, closes findings with named owners, audits on schedule, and gets sign-off from someone with the authority to accept risk - is not a line item to build. It is a line item to redirect. Talk to MacTech about what that redirection actually removes from the quote you were given, because the honest number is lower than the one that assumed you were starting from nothing. ◆

FIELD COPY
ISSUE Nº 027
AS9100

3.12.4

THE NIST 800-171 CONTROL ASKING FOR A CURRENT SSP - DOCUMENT CONTROL'S JOB UNDER A DIFFERENT NAME

320

ASSESSMENT OBJECTIVES AN 800-171A ASSESSOR VERIFIES ONE AT A TIME, NOT SAMPLES

3

GAPS A QUALITY SYSTEM CANNOT CLOSE ON ITS OWN - BOUNDARY, TECHNICAL CONTROLS, AND THE TEST ITSELF

◆ SAMPLED VERSUS VERIFIED, PRECISELY

An AS9100 surveillance audit works from a representative sample of records and infers the rest of the system from it. NIST 800-171A gives an assessor no such shortcut - it directs them to examine, interview, and test until each objective is confirmed for the control in front of them, one at a time.